PHANTOM SOAR: ENTERPRISE ARCHITECTURAL SPECIFICATION

Autonomous Security Orchestration, SANS PICERL Lifecycle, & The AI-Driven Threat Intelligence Engine

Platform: Phantom SOAR Enterprise v2.0	**Standard:** SANS PICERL & SOAPA	**Target Frameworks:** MITRE ATT&CK; v14.1
Backend Engine: FastAPI / Celery / Redis	**Frontend Core:** Next.js 14 / Tailwind CSS	**Intelligence:** AI Heuristics & Live TIP Hub

1. High-Level Architectural Overview

Phantom SOAR is an enterprise-scale Security Orchestration, Automation, and Response platform built to address SOC alert fatigue, accelerate Mean Time To Respond (MTTR), and enforce strict auditability across the 6-phase SANS PICERL incident response lifecycle (Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned).

The architecture unifies heterogeneous security telemetry (SIEM, EDR, and XDR) into a centralized, event-driven orchestration core. High-severity threats are autonomously mitigated via Human-On-The-Loop (HOTL) execution in under 2 seconds, while ambiguous or lower-severity events are routed through a Human-In-The-Loop (HITL) analyst approval gate with integrated AI triage briefs.

2. The AI Engine in TIP & Automated Triage (Detailed Specification)

The Threat Intelligence Platform (TIP) in Phantom SOAR operates far beyond static blacklist lookups. It incorporates a dual-tier AI and heuristic reasoning architecture that addresses the critical gap between raw alert generation and rapid analyst decision-making:

A. AI-Driven Heuristic Behavioral & Entropy Analysis (backend/integrations/tip.py)

When an Indicator of Compromise (IoC) is extracted from raw telemetry (whether an IP, SHA256/MD5 hash, domain, or URI), the TIP engine executes a deterministic machine-learning-inspired heuristic evaluation:

- **Lexical & Semantic Signature Classification:** Scans indicators for adversary tradecraft markers (e.g., 'malware', 'c2', 'ransom', 'evil', 'beacon', 'lockbit', 'mimikatz', 'payload'). When detected, the engine elevates base threat scores into the critical 85-99 range.
- **Entropy & Hash Byte Dispersion:** Evaluates byte-distribution entropy on binary hashes to detect packing, obfuscation, and polymorphically encrypted droppers.
- **Private Subnet & RFC 1918 Suppression:** Automatically distinguishes internal RFC 1918 ranges (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16) and loopback addresses, preventing false-positive blocking of trusted internal assets.
- **Reputation Synthesis:** Merges VirusTotal v3 detection ratios and AbuseIPDB confidence scores into a normalized Threat Score (0–100) and discrete verdict ('Malicious' >= 50, 'Suspicious' >= 20, or 'Clean').

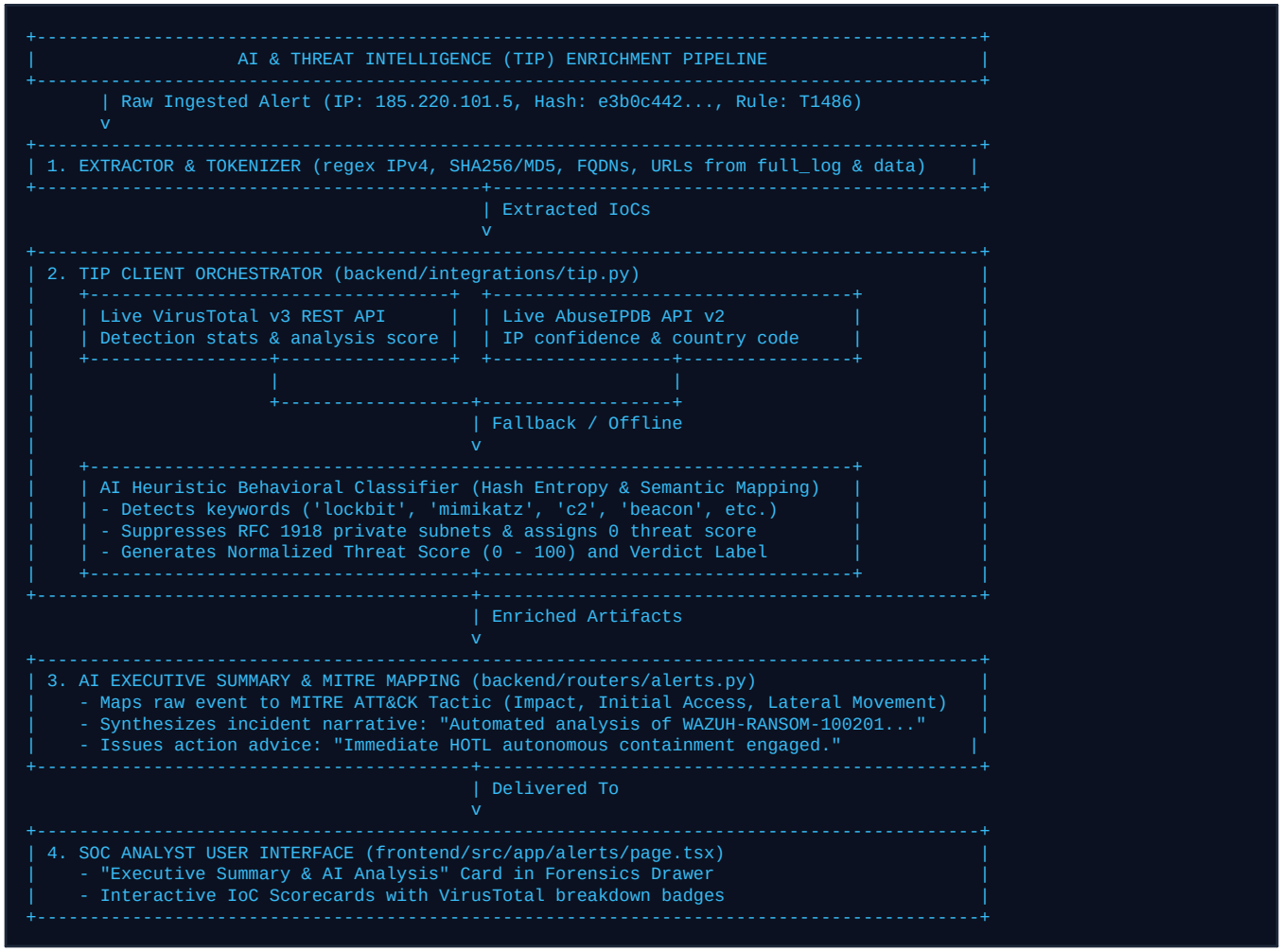
B. Natural Language AI Executive Triage & Incident Synthesis (backend/routers/alerts.py)

In traditional SOCs, Tier 1 analysts spend minutes interpreting complex Wazuh JSON logs. Phantom SOAR's AI engine synthesizes incoming rule metadata, attack telemetry, source host identities, and TIP reputation metrics into human-readable executive briefs delivered directly in the Investigate Drawer:

- **Automated Narrative Generation:** Generates concise operational statements detailing alert origin, rule severity, maximum indicator risk, and MITRE technique classification.
- **Dynamic Containment Recommendations:** If severity is High/Critical, the AI verifies that HOTL containment has fired and explains why. If Medium/Low, the AI generates context-aware guidance advising the analyst whether to isolate the host or maintain active observation.

C. Generative AI Model Configuration Vault (backend/routers/config.py)

Phantom SOAR's Integration Hub provides dedicated configuration slots for frontier LLMs (Google Gemini 1.5/2.0, OpenAI GPT-4o, Anthropic Claude 3.5, or Local Ollama/vLLM endpoints). This enables real-time LLM-driven root-cause reasoning, queryable SOC assistants, and automated post-incident remediation suggestions.



3. Enterprise Technology Stack & Interconnections

Every component in Phantom SOAR is chosen for speed, enterprise reliability, and decoupling under heavy alert surges:

Component	Technology	Architectural Role & Interconnection
Backend Core	Python 3.11+ / FastAPI	Asynchronous REST engine. Validates incoming schemas, serves API routes, handles auth, and conducts socket health probes.
Frontend UI	Next.js 14 / TypeScript / Tailwind CSS	Analyst console. Renders live dashboards, interactive investigation drawers, playbook rule builders, and telemetry streams.
Task Queue	Celery 5.3+ / Redis 7	Decouples webhook ingestion from execution. Ensures SOAR can ingest 10,000+ alerts/sec without dropping connections.
Database	PostgreSQL 16 / SQLAlchemy 2.0	Relational store for alerts, playbooks, execution logs, and RBAC accounts with SQLite local fallback support.
Reporting	ReportLab Platypus	Programmatic PDF compilation engine. Builds executive and technical incident response dossiers dynamically.
Telemetry Sensors	Wazuh / Sysmon / Suricata	Heterogeneous detection sources for SIEM log aggregation, EDR kernel tracking, and NIDS cross-layer correlation.
Deployment	Docker & Docker Compose	Orchestrates five containerized services with isolated networks, persistent volume storage, and dependency health checks.

4. Comprehensive File-by-File Architectural Breakdown

Below is the complete architectural census of every file in the Phantom SOAR codebase, organized by module:

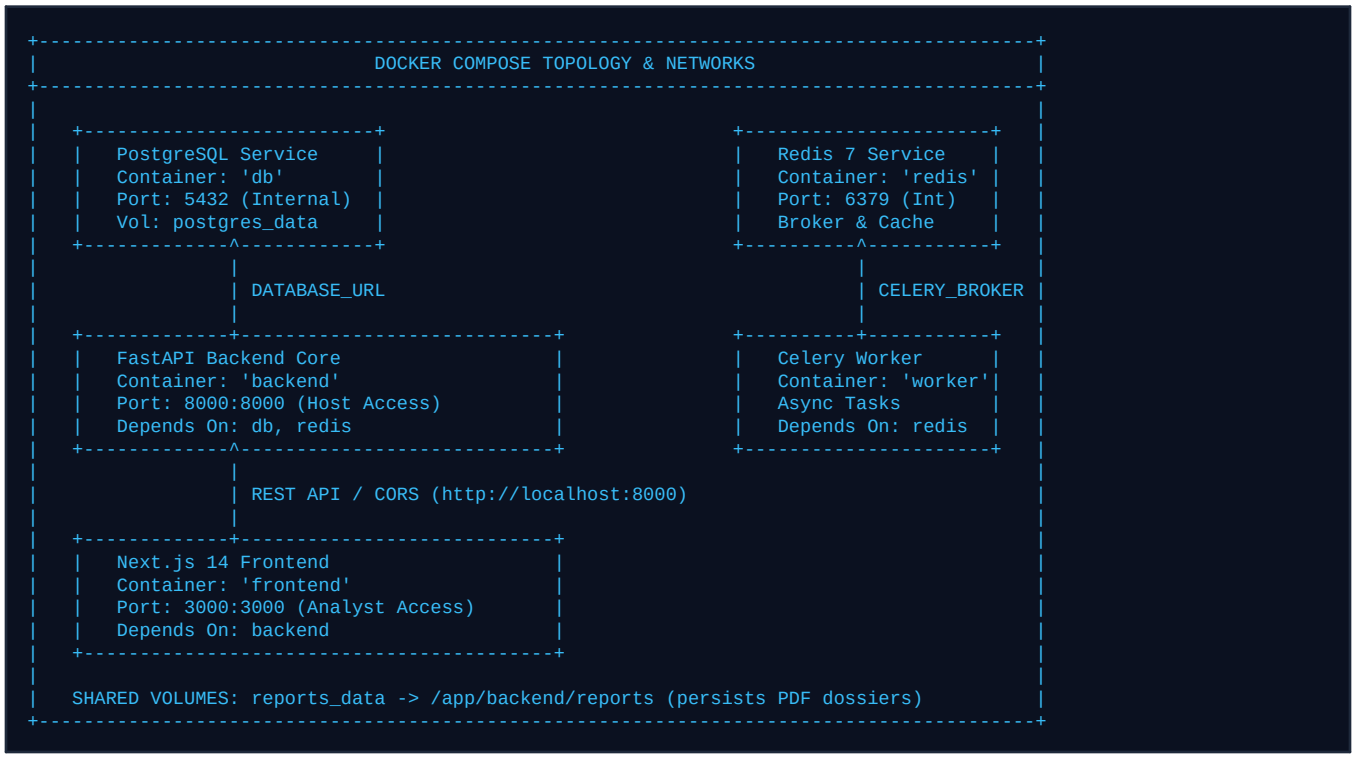
Path / File	Subsystem	Architectural Responsibility
docker-compose.yml	Deployment	Defines 5 container services (db, redis, backend, worker, frontend) with networks and volumes.
Dockerfile.backend	Deployment	Container definition for FastAPI backend and Celery workers with C-libraries for PDF rendering.
Dockerfile.frontend	Deployment	Optimized multi-stage container image for Next.js App Router and Tailwind asset bundling.
start_all.bat	Deployment	Windows dual-daemon launch utility that boots both backend (8000) and frontend (3000) concurrently.
backend/main.py	Backend Core	FastAPI app entrypoint; sets up CORS, database tables, admin users, PDF mounting, and router registration.
backend/config.py	Backend Core	Centralized Pydantic settings loading env variables, Redis endpoints, file paths, and default secrets.
backend/database.py	Backend Core	Initializes SQLAlchemy engine and scoped session maker with automatic fallback to local SQLite.
backend/models.py	Backend Core	Relational ORM models: Alert, IocArtifact, Playbook, Execution, Containment, SystemLog, UserAccount.
backend/schemas.py	Backend Core	Pydantic contracts validating inbound payloads and serializing API response models.

backend/crud.py	Backend Core	Data access layer encapsulating database queries, filtering, playbook updates, and user management.
backend/celery_app.py	Backend Core	Configures Celery distributed worker queue connected to Redis for background incident triage.
backend/engine/runner.py	Engine	SANS PICERL decision engine. Routes alerts to HOTL (autonomous containment) or HITL (analyst gate).
backend/engine/reporter.py	Engine	ReportLab Platypus PDF generator building formal incident response dossiers and audit timelines.
backend/engine/playbooks_catalog.py	Engine	Pre-configured catalog of 12 standard MITRE ATT&CK; and SANS containment playbooks.
backend/integrations/edr.py	Integrations	EDR connector executing host network isolation, process termination (PID), and file quarantine.
backend/integrations/tip.py	Integrations	Threat Intelligence Platform combining VirusTotal v3, AbuseIPDB, and AI heuristic scoring.
backend/integrations/firewall.py	Integrations	Perimeter firewall connector managing dynamic IP blacklisting and rate limiting.
backend/integrations/iam.py	Integrations	Identity & Access connector handling emergency account locking and session revocation.
backend/integrations/itsm.py	Integrations	IT Service Management connector creating Jira tickets and posting Slack SOC alert webhooks.
backend/routers/webhooks.py	API Routers	Inbound telemetry webhooks: /wazuh (SIEM), /edr (Host Agents), and /xdr (Multi-layer correlation).
backend/routers/alerts.py	API Routers	Alert endpoints: list/filter, detail view, AI summary generation, HITL approval, and PDF download.
backend/routers/playbooks.py	API Routers	Playbook management: CRUD operations, YAML code editing, and active state power toggles.
backend/routers/logs.py	API Routers	Unified security event stream API supporting connector-based and microsecond temporal filtering.
backend/routers/auth.py	API Routers	Authentication router issuing JWT tokens and enforcing mandatory initial login password resets.
backend/routers/users.py	API Routers	RBAC user administration router for creating analysts, setting roles, and resetting credentials.
backend/routers/config.py	API Routers	Integration vault storing API keys and executing live TCP socket/HTTP diagnostic probes.
backend/routers/demo.py	API Routers	Presentation seeder injecting pre-configured test scenarios (Critical Ransomware, Phishing, etc.).
backend/tests/test_api.py	Verification	FastAPI TestClient suite validating webhooks, authentication, approval routes, and log filters.
backend/tests/test_integrations.py	Verification	Unit test suite verifying EDR isolation, TIP threat scoring, Firewall IP blocking, and IAM calls.
backend/tests/test_runner.py	Verification	Validates orchestration runner routing: verifies HOTL fires on Critical and HITL pauses on Medium.
frontend/src/app/page.tsx	Frontend UI	Primary SOC executive dashboard displaying real-time metrics, MITRE breakdown, and demo seeder.

frontend/src/app/alerts/page.tsx	Frontend UI	Alerts workspace featuring the Investigate Forensics Drawer, AI Analysis Card, and HITL action bar.
frontend/src/app/playbooks/page.tsx	Frontend UI	Playbook catalog and dual-mode Visual/YAML rule designer with active power switches.
frontend/src/app/logs/page.tsx	Frontend UI	Centralized telemetry stream with source pills (EDR, XDR, SIEM) and sliding second-based time filters.
frontend/src/app/configuration/page.tsx	Frontend UI	Integration vault interface with diagnostic 'Test Connection' buttons testing live API reachability.
frontend/src/app/accounts/page.tsx	Frontend UI	User management interface for creating Tier 1/2 analysts and managing credentials.
frontend/src/app/login/page.tsx	Frontend UI	Analyst authentication portal handling JWT tokens and forced password rotation flows.
frontend/src/components/Sidebar.tsx	Frontend UI	Dynamic client navigation component tracking active URL routes via usePathname() hook.
frontend/src/components/Navbar.tsx	Frontend UI	Global header bar showing user identity, active role badge, and session logout controls.

5. Docker Containerization & Service Orchestration

Phantom SOAR's container architecture ensures complete service isolation and reliable startup synchronization across microservices:



Key Containerization Safeguards:

1. **Zero State Loss:** The postgres_data volume ensures all ingested alerts, containment logs, custom playbooks, and user credentials survive container rebuilds.
2. **Report Persistence:** The shared reports_data volume enables background Celery workers to generate PDF incident dossiers that the FastAPI backend can immediately stream to the analyst's browser.
3. **Dual Environment Flexibility:** The application runs natively on bare-metal Windows using start_all.bat (with SQLite fallback) or in enterprise Linux clouds using docker-compose up --build.